Collectrix Ai

TENANT PORTAL · PRODUCT UPDATE

Roles & Permissions

What we changed, how permissions are now organised, and what the backend needs to do, explained in plain language.

Frontend: complete | Backend: changes needed | App works as before until then

2 **How permissions work**
Roles, modules, pages and actions, explained simply.

3 **The full permission map**
All 76 permissions, organised like the left menu.

4 **What changed in the app**
The new roles screen, the editor and protected pages.

5 **The backend to-do list**
Every endpoint change, with examples.

Document
Version 1.0

Date
5 October 2026

Audience
Whole team

CONTENTS

What's inside

You don't need to read everything. Start with the summary, then jump to the part that matches your job.

1 **Summary** What we did, why, and where things stand 3

2 **How permissions work now** Roles, modules, pages and actions in simple terms 4

3 **How we divided the permissions** The complete list, module by module, plus presets 6

4 **What changed in the app** The new roles screen, editor, and protected pages 12

5 **What the backend needs to do** Every endpoint change, with examples 14

6 **Rollout plan** The order to ship things in, and who does what 19

7 **How to test it** A checklist for QA once the backend is live 20

8 **Glossary** Plain meanings of the words used here 21

A **Appendix: endpoint lookup** Which permission each backend endpoint needs 22

Who should read what

Everyone
Sections 1 to 3: what changed and how permissions are organised.

Product and tenant admins
Sections 3, 4 and 6: presets, the new editor, and the review after migration.

Backend developers
Section 5 and the appendix: the exact changes and which permission each endpoint checks.

QA
Section 7: what to test and what should happen.

SECTION 1 · FOR EVERYONE

1 Summary

The Roles & Permissions module decides what each person in a workspace can see and do. The first version was a placeholder, so we rebuilt it from scratch around the pages and server calls the app really uses.

8	22	76	5
modules, matching the left menu	pages and profile tabs	permissions in total	ready-made presets

Why we changed it: before and after

The old list didn't match the app's pages, repeated the same permission in several places, covered features that don't exist yet (Payments, Legal Actions, Appointments) and left almost every page open to everyone.

AREA	BEFORE	NOW
Permission list	38 numbered items in 7 groups that didn't match the menu	76 named permissions, organised exactly like the left menu
What was protected	A handful of actions on customer files	Every live page and every action button
Opening pages	Any signed-in user could open any page	A page only appears for roles allowed to open it
Role editor	Two different groupings of the same items, side by side	One grid: module, page, then View, Create, Edit, Delete and special actions
Role descriptions	Not stored by the server, so they were lost	Stored and shown on every role
Deleting a role	Not possible	Possible once nobody uses the role
Document Automation	Mock page in the menu with no server behind it	Removed

Where things stand, and who does what next

TEAM	STATUS	NEXT STEP
Frontend	Done New design, roles screen and editor; every live page protected; Document Automation removed; tested in the browser.	Remove the temporary translation code once the backend is live.
Backend	To do Nothing changed yet.	Make the changes in section 5 and convert existing roles in the same release.
Product and tenant admins	After backend	Review every role and remove sensitive permissions from roles that shouldn't manage users or roles.
QA	After backend	Run the checklist in section 7.

NOTHING BREAKS IN THE MEANTIME

Until the backend is updated, the app works exactly as it does today. The roles screen shows every role in the new format but stays read-only.

SECTION 2 · FOR EVERYONE

2 How permissions work now

A few simple ideas explain the whole system. Once these click, the rest of the document is easy to follow.

IN SIMPLE WORDS

Think of a **role** as an access card. The card says which parts of the app a person can enter and what they are allowed to do once inside. Everyone who has the same role gets the same card. Each user has exactly one role.

2.1 Three levels: module, page, action

LEVEL 1

Module

A group in the left menu.

e.g. **Case Files**, **Access Control**

→

LEVEL 2

Page

A screen inside the module, or a tab on a customer's profile.

e.g. **Customers**, **Notes**

→

LEVEL 3

Action

One thing a person can do on that page.

e.g. **View**, **Delete**, **Send SMS**

Case Files → **Notes** → **Delete** = "can delete notes on a customer file"

2.2 The actions

Most pages use four standard actions:

ACTION	MEANS
View	Open the page and read what's on it.
Create	Add something new, like a note, a team or a template.
Edit	Change something that already exists.
Delete	Remove something.

When those four aren't specific enough, a page gets **special actions**, for example *Send SMS*, *Place calls*, *Archive*, *Take on*, *Release* a phone number, or *Export*. Not every page has every action. Activity & audit, for instance, can only be viewed and exported.

2.3 Two automatic rules

Rule 1 · You can't act on what you can't see

Turning on any action also turns on that page's **View**. Turning off View turns off everything else on that page.

Rule 2 · Some pages build on others

A few pages only make sense together with another page, so the editor switches those on as a pair. See the table below.

IF YOU GIVE	THEY ALSO GET	WHY
Notes, SMS & email, Calls or Documents · View	Customers · View	These are tabs inside a customer's profile.
Inbound Inbox · View	Customers · View and SMS & email · View	The inbox shows customer files and their message threads.

The editor applies both rules for you and shows a short message whenever it turns something on or off because of them.

2.4 The Tenant Administrator

Every workspace has a built-in owner role called **Tenant Administrator**. It always has every permission, it can't be edited or deleted, and it can never be locked out. Use it to fix any role mistake.

2.5 Permission code names

Behind each permission is a short code name that both the app and the server use. It is written as *page.action*, for example `customers.notes.delete`. Code names never change once created, so they are safe to store and to check on the server. You'll see them in sections 3 and 5.

HIDING IS NOT BLOCKING

The app hides menus and buttons a role can't use, so people only see what they can do. That is a convenience. The server must also refuse those requests. That part is the backend's job, described in section 5.1.

WHAT PERMISSIONS DON'T CHANGE

Permissions decide what someone can *do*, not which customer files they *see*. For example, the Customers list still shows only the files assigned to the signed-in agent, exactly as today.

SECTION 3 · FOR EVERYONE

3 How we divided the permissions

Permissions follow the left menu, so finding a permission is as easy as finding its page. Here is the complete list.

3.1 Overview

MODULE	PAGES	PERMISSIONS
Case Files	Customers, Notes, SMS & email, Calls, Documents, Team Deck, Moved Files, Archive	28
Inbound Inbox	Inbound Inbox	2
Engagement	Phone numbers, Template library	8
Data Intake	Client list, Upload customer data, Mass update	11
Compliance	Activity & audit	2
Access Control	Users, Teams, Roles & permissions	13
Configuration	Tenant settings, Data fields	6
System Configuration	Statuses, Status automation	6
Total	22 pages	**76**

WHY CUSTOMER PROFILE TABS ARE SEPARATE PAGES

Each tab on a customer's profile (Notes, SMS & email, Calls and Documents) talks to its own set of server calls, so each has its own permissions. That means you can, for example, let someone listen to call recordings without letting them place calls.

Permissions marked Sensitive control who can access what, such as adding users or changing roles. Give those only to people who should manage access.

3.2 The complete list

Case Files · Customer files and the team queues they move through.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Customers	**View** `customers.view`	Open the Customers list and customer profiles, including flags and the activity timeline.
	Edit `customers.edit`	Change a customer's contact, financial and file details.
	Change status `customers.changeStatus`	Set a file's status, one at a time or in bulk.
	Manage flags `customers.manageFlags`	Add and remove flags on a file.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
	Move to team `customers.moveTeam`	Transfer files to another team's Moved Files queue.
	Archive `customers.archive`	Park a file in the Archive, out of the active workload.
	Stop engagement `customers.stopEngagement`	Pause all outreach on a file.
	Resume engagement `customers.resumeEngagement`	Restart outreach on a file where it was stopped.
	Export `customers.export`	Download customer files as CSV.
Notes	**View** `customers.notes.view`	Read a file's notes and open their attachments.
	Create `customers.notes.create`	Add notes, with attachments, to a file.
	Edit `customers.notes.edit`	Change any note on a file.
	Delete `customers.notes.delete`	Delete any note on a file. A reason is always required.
SMS & email	**View** `customers.messages.view`	Read the SMS and email history on a file.
	Send SMS `customers.messages.sendSms`	Text a customer from the profile or the inbox.
	Send email `customers.messages.sendEmail`	Email a customer from the profile or the inbox.
Calls	**View** `customers.calls.view`	Play recordings and read call transcripts and summaries.
	Place calls `customers.calls.place`	Call a customer from one of the tenant's caller IDs.
Documents	**View** `customers.documents.view`	See and download a file's generated documents.
	Generate `customers.documents.generate`	Generate a document for a file from one of its client's templates.
	Delete `customers.documents.delete`	Delete a generated document.
Team Deck	**View** `teamDeck.view`	Browse each team's deck and the files its members are working.
	Assign to member `teamDeck.assign`	Hand deck files to a team member, or reassign them.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Moved Files	**View** `movedFiles.view`	See the files moved to each team.
	Take on `movedFiles.takeOn`	Set a status on moved files and hand them to a member.
Archive	**View** `archive.view`	Browse and search archived files.
	Restore `archive.restore`	Return an archived file to its team's active workload.
	Export `archive.export`	Download the archive list as CSV.

Inbound Inbox · Customer replies by SMS and email, in one place.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Inbound Inbox	**View** `inbox.view`	Open the inbox and read conversations.
	Reassign `inbox.assign`	Hand a conversation's file to another member of its team.

Engagement · The phone numbers and templates outreach is sent with.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Phone numbers	**View** `phoneNumbers.view`	See the tenant's numbers and their status.
	Buy `phoneNumbers.buy`	Search for and buy new numbers.
	Edit `phoneNumbers.edit`	Turn numbers on or off and choose whether each one calls, texts or both.
	Release `phoneNumbers.release`	Release a number permanently. It can't be recovered.
Template library	**View** `templates.view`	Browse every template, voice agent and prompt.
	Create `templates.create`	Add templates, voice agents and prompts.
	Edit `templates.edit`	Change existing templates, voice agents and prompts.
	Delete `templates.delete`	Delete templates, voice agents and prompts.

Data Intake · Clients, customer file imports and bulk updates.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Client list	View `clients.view`	See every client and its channel settings.
	Create `clients.create`	Add clients.
	Edit `clients.edit`	Rename clients and change which channels they allow.
	Delete `clients.delete`	Delete clients.
Upload customer data	View `imports.view`	See past imports and the records in each one.
	Upload `imports.upload`	Validate and import a new customer file.
	Fix records `imports.edit`	Correct records that were flagged during validation.
	Assign to team `imports.assignTeam`	Hand imported files to a team.
Mass update	View `massUpdate.view`	Browse and filter files for a mass update.
	Apply updates `massUpdate.apply`	Upload a corrected spreadsheet and update the files in bulk.
	Download spreadsheet `massUpdate.export`	Download the selected files as a spreadsheet.

Compliance · The tenant's audit trail.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Activity & audit	View `audit.view`	Search and filter the audit log.
	Export report `audit.export`	Download the filtered audit log as CSV.

Access Control · Who can sign in, the teams they belong to, and what they can do.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Users	View `users.view`	See every user, their role, teams and numbers.
	Add Sensitive `users.create`	Invite new users and choose their role.
	Edit Sensitive `users.edit`	Change a user's details, role, teams and numbers.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
	Reset password `users.resetPassword`	Generate a password reset link for a user.
	Activate & deactivate `users.deactivate`	Block a user from signing in, or let them back in.
Teams	**View** `teams.view`	See teams as cards or as an org chart.
	Create `teams.create`	Create teams.
	Edit `teams.edit`	Change a team's name, leader, members and numbers.
	Delete `teams.delete`	Delete a team. Its members and numbers are released.
Roles & permissions	**View** `roles.view`	See every role and its permissions.
	Create Sensitive `roles.create`	Create roles.
	Edit Sensitive `roles.edit`	Change a role's name and permissions.
	Delete Sensitive `roles.delete`	Delete roles that no user is assigned to.

Configuration · Workspace-wide settings.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Tenant settings	**View** `settings.view`	See the organization, hours and connector settings.
	Edit `settings.edit`	Change the organization profile, operating hours and connectors.
Data fields	**View** `dataFields.view`	See the default and custom data fields.
	Create `dataFields.create`	Add custom fields.
	Edit `dataFields.edit`	Rename custom fields or change their type.
	Delete `dataFields.delete`	Delete custom fields.

System Configuration · The account lifecycle and what happens automatically at each step.

PAGE	PERMISSION	WHAT IT LETS SOMEONE DO
Statuses	**View** `statuses.view`	Open the Statuses page.
	Create `statuses.create`	Add statuses.
	Edit `statuses.edit`	Rename and recolour statuses. Changes apply to every file on them.
	Delete `statuses.delete`	Delete statuses no file is on.
Status automation	**View** `statusAutomation.view`	See the automation configured for each team and client.
	Edit `statusAutomation.edit`	Change initial statuses and the automation on each status.

3.3 Presets: ready-made starting points

When creating a role, you can start from a preset instead of an empty grid. A preset only fills in the checkboxes; you can change anything before saving, and nothing about the preset is stored.

PRESET	WHO IT'S FOR	WHAT'S INCLUDED	PERMISSIONS
Collections agent	People who work their own customer files	Open customers, change status, manage flags, stop engagement, read and add notes, read and send SMS and email, listen to and place calls, view and generate documents, use the inbox.	14
Team lead	People who run a team	Everything an agent has, plus: edit customer details, move files to another team, archive, resume engagement, export, edit and delete notes, delete documents, assign Team Deck files, take on moved files, restore from Archive, reassign in the inbox, see teams.	30
Operations manager	People who run the whole book of business	Everything a team lead has, plus: Data Intake (clients, uploads, mass update), the template library, phone numbers (view), statuses, status automation, the audit log and the user list. No control over users or roles.	55
Compliance auditor	Reviewers who should see but not change	View on every page, plus exporting the audit log.	23
Full access	Senior administrators	Every permission.	76

SECTION 4 · FOR EVERYONE

4 What changed in the app

Everything below is already built in the tenant portal. Most of it is visible today; editing roles unlocks once the backend is updated.

4.1 The Roles & Permissions screen

- Each role is a card showing its name, description, how many people have it, how many permissions it has, and which modules it can reach. An eye icon next to a module means view-only.
- Your own role is marked **Your role**.
- A built-in **Tenant Administrator** card shows the owner role, which always has full access.
- Each card's menu offers **Edit** (or **View** if you can't edit), **Duplicate** and **Delete**. Delete is blocked while anyone still has the role, and the menu says how many people to move first.
- The New role, Edit and Delete options only appear if your own role allows them.
- Until the backend is updated, the screen is read-only, with a notice explaining why: saving the new format to the old server could wipe a role's permissions. Everyone keeps exactly the access they have today in the meantime.

4.2 The role editor

Finding things

- A list of modules on the left, each with a checkbox for all, none or some, and a count such as "18/28 · Custom". Click a module to jump to it.
- A search box to find any permission by name.
- Hover any checkbox to see what it allows.

Choosing permissions

- One card per module and a row per page, with columns for View, Create, Edit and Delete, and chips for special actions. A dash means the action doesn't exist on that page.
- A quick switch on each module: **None**, **View only** or **Full**.
- **Start from preset**, **Select all** and **Clear**.

Staying safe

- Sensitive permissions are marked with a shield.
- A warning if you remove your own ability to edit roles.
- A note when a role has no permissions at all.
- The automatic rules from section 2.3, with a short message when they apply.

Saving

- An unsaved-changes counter, such as "+3 −1".
- A "Discard your changes?" prompt if you close without saving.
- Every role needs a name, and two roles can't share one.
- Works on phones: the columns become labelled chips.

4.3 Pages and buttons now follow permissions

- The left menu, the ⌘K search and the Case Files hub only show pages your role can open.
- Opening a blocked page directly, for example from a bookmark, shows **"Your role can't open this page"** and names the permission needed.

- Inside each page, buttons for actions your role can't take are hidden. Where a role can view but not change something, the form is shown read-only.

PAGE	NOW CONTROLLED BY PERMISSIONS
Customers list	Selecting files for bulk actions, Assign status, Move to team, Export, Add customer
Customer profile	Status, flags and Edit details; the Communication, Calls, Documents and Notes tabs; sending SMS and email; placing calls; generating and deleting documents; adding, editing and deleting notes; the Manage menu (Export, Edit, Move to team, Archive, Restore, Stop or Resume engagement)
Inbound Inbox	Replying by SMS or email, calling, changing status, stopping or resuming engagement, reassigning, flags and notes
Team Deck	Assign and Reassign to a member
Moved Files	Take on
Archive	Restore and Export CSV
Phone numbers	Buy numbers, Configure, Release
Template library	New, Edit and Delete on every tab: email, SMS, documents, AI voice agents and AI prompts. Editors are read-only without Edit.
Client list	Add, Configure, Delete
Upload customer data	New import, Fix records, Assign to team
Mass update	Download spreadsheet and the Update data tab
Activity & audit	Export report
Users	Add user; Manage (the profile is read-only without Edit); Reset password; Activate and deactivate
Teams	New team, Edit, Delete
Roles & permissions	New role, Edit (view-only otherwise), Duplicate, Delete
Tenant settings	The Organization, Hours and Connectors tabs and saving them; the Data Fields tab and adding, editing and deleting fields
Statuses	New status, Edit, Delete
Status automation	Saving changes, changing the initial status, editing each status's automation (read-only otherwise)

4.4 Smaller improvements

- The sidebar now shows your real role name under your name. It used to say "Tenant Administrator" for everyone.
- Your permissions load once when you sign in and are remembered, so pages open instantly. They are refreshed on every visit and straight after a role is saved.
- If permissions fail to load, the app says so and offers **Try again** instead of guessing.

4.5 Removed

- **Document Automation**, both the menu item and the page. It was a mock with no server behind it and is no longer part of the product. Generating documents from a customer's Documents tab is unaffected.
- The old placeholder permission code, which the new system replaces.

SECTION 5 · MAINLY FOR BACKEND DEVELOPERS

5 What the backend needs to do

Ten items in total. Each one is explained in plain words first, followed by the exact details and an example where it helps.

IN SIMPLE WORDS

An **endpoint** is an address on our server that the app calls to read or save data, such as `/tenant/getAllRole`. How we call the server doesn't change: every request is still a **POST** with the user's login token, and every answer still uses the usual `{ meta, data }` format, where `meta.status: true` means it worked.

Checklist

#	WHAT	TYPE	IN ONE LINE
1	Every endpoint	RULE	Refuse requests from people without the right permission
2	`getAllRole`	CHANGED	Return each role's permissions and description
3	`createRole`	CHANGED	Save a new role with its permissions
4	`updateRole`	CHANGED	Save changes to a role; apply them immediately
5	`deleteRole`	NEW	Delete a role nobody uses
6	`myProfile`	CHANGED	Include the signed-in user's own permissions
7	`getConfiguredRoles`	RETIRED	No longer used; the permission list lives in the app
8	Saving a role	RULE	Check names and code names whenever a role is saved
9	Existing roles	ONE-OFF	Convert old permission numbers to the new code names
10	`getTenantDetails`	FIX	Stop sending the email password back to the browser

5.1 Checking permissions on every request RULE

THIS IS THE MOST IMPORTANT CHANGE

For every request, the server looks up the person's role and checks it has the permission that endpoint needs. If it doesn't, refuse. Appendix A lists the permission for every endpoint the app uses.

How to refuse: keep the usual format: `meta.status: false`, `code: 403`, and a clear message such as *"You don't have permission to delete notes."* The app shows that message to the user. An HTTP 403 status also works.

Endpoints with special rules. Some endpoints are shared by several pages, so they don't belong to a single permission:

ENDPOINTS	WHO MAY CALL THEM
`getclientList` `getStatusList` `getAllStatus` `getTeamList` `getMovedTeamList` `assignTeamList`	Anyone signed in. These fill small pickers used across many pages.

ENDPOINTS	WHO MAY CALL THEM
`myProfile` `updateProfile` `uploadProfilePic` `sendResetMyPasswordLink` `getTimezoneList` `/user/logout`	Anyone signed in, acting on their own account.
`getAllClients`	`clients.view` or `imports.view`. The upload screen needs the client list.
`getClientTemplate`	`templates.view` or `statusAutomation.view`. Status automation picks templates.
`getTeamDeckAssignUserList`	Any of `teamDeck.assign`, `movedFiles.takeOn`, `inbox.assign`, `statusAutomation.view`
`getRoleList`	`users.view`, for the role picker on the user form
`getTeamPhoneNumber`	`users.create` or `users.edit`
`getAllLeaderList` `getUnassignedTeamMemember` `getTeamNumbers`	`teams.create` or `teams.edit`, for the team form
`/user/login` `validateResetPassword` `resetPassword` `getInviteCodeDetails` `makePayment` `completeTenantInviteOnboard`	Public, no sign-in. Unchanged.

Checked only in the app. Four permissions have no endpoint of their own: `customers.export`, `archive.export` and `audit.export` build CSV files from data the person can already see, and `statuses.view` opens a page whose data comes from a shared picker. The server doesn't need to check these.

5.2 List roles

POST `/tenant/getAllRole` CHANGED

What it's for: Lists every role in the workspace for the Roles & Permissions screen. Callers need **Roles & permissions · View**.

- Add `permissions` to each role: the list of permission code names it has. This replaces `allowedConfiguration`, the old list of numbers.
- Add `roleDescription` to each role. Today it isn't returned, so descriptions get lost.
- Add `permissionSchema: 2` to the response, so the app knows the new format is live and unlocks editing.
- `totalConfiguration` is no longer needed.

EXAMPLE RESPONSE (DATA PART)

```
{
  "permissionSchema": 2,
  "roles": [{
    "roleId": 4, "roleName": "Collections agent", "userCount": 12,
    "roleDescription": "Works their own files",
    "permissions": ["customers.view", "customers.changeStatus", "inbox.view"]
  }]
}
```

5.3 Create a role

POST `/tenant/createRole` CHANGED

What it's for: Creates a new role. Callers need **Roles & permissions · Create**.

- Send `roleName`, `roleDescription` and `permissions`, a list of code names.
- Return the new `roleId`.

EXAMPLE REQUEST, THEN RESPONSE (DATA PART)

```
{ "roleName": "Team lead", "roleDescription": "Runs a team", "permissions": ["customers.view", "teamDeck.view", "teamDeck.assign"] }

{ "roleId": 9 }
```

5.4 Change a role

POST `/tenant/updateRole` CHANGED

What it's for: Saves changes to an existing role's name, description and permissions. Callers need **Roles & permissions · Edit**.

- Send `roleId` plus the same fields as createRole. The app always sends the **full** list of permissions, not just what changed.
- Changes must take effect on the **very next request** from every person with this role. Nobody should need to sign out and back in.

EXAMPLE

```
{ "roleId": 4, "roleName": "Team lead", "roleDescription": "Runs a team", "permissions": ["customers.view", "teamDeck.view"] }
```

5.5 Delete a role

POST `/tenant/deleteRole` NEW

What it's for: Deletes a role. This endpoint doesn't exist yet. Callers need **Roles & permissions · Delete**.

- Send `roleId`.
- Refuse while anyone still has the role, with `meta.status: false` and the message *"This role is assigned to N users. Move them to another role first."*

EXAMPLE

```
{ "roleId": 4 }
```

5.6 The signed-in user's own details

POST `/tenant/myProfile` CHANGED

What it's for: Returns the signed-in person's own details. The app calls it right after sign-in. Anyone signed in may call it.

- Add `permissions`: that person's own list of permission code names.
- **Why:** listing roles now needs a permission, so a regular agent can't read the roles list. This field is how they learn their own permissions.
- For the Tenant Administrator, send an empty list or every code name. The app gives full access either way.

EXAMPLE RESPONSE (DATA PART)

```
{
  "userId": 17, "roleId": 4, "role": "Collections agent",
  "...": "all existing fields stay the same",
  "permissions": ["customers.view", "customers.messages.view", "inbox.view"]
}
```

5.7 The old permission catalog

POST `/tenant/getConfiguredRoles` RETIRED

What it's for: Used to send the old list of numbered permissions. The app no longer calls it.

The full list of permissions now lives in the app, in `src/lib/permissions/catalog.ts`, and in this document. The server still needs the list of valid code names so it can check what gets saved. Keep a copy; appendix A and section 3 list every one.

5.8 Rules when saving a role

These apply to both createRole and updateRole. When a save is refused, reply with `meta.status: false` and the message shown below; the app displays it to the user.

SITUATION	WHAT THE SERVER SHOULD DO
The role name is empty	Refuse: *"Role name is required."*
Another role already has the name (ignoring upper and lower case)	Refuse: *"Role name already exists."*
A code name isn't in the official list	Refuse: *"Unknown permission: <code name>."*
A permission's requirements are missing, for example Notes · Delete without Notes · View	Add the missing ones before saving (the rules in section 2.3). The app always sends a complete set, so this only protects against other clients.
The permission list is empty	Allow it. People with that role can only open the Overview page.

5.9 Converting existing roles ONE-OFF

Existing roles store a list of old permission numbers. Each role needs converting to code names **once**, in the same release as the changes above. The goal: on day one, nobody gains or loses any access.

1. Start every role with all 76 code names, then take out the 18 permissions listed in the right-hand column of the table below.

2. Give each of those back if the role had the old number next to it. For example, a role with old number **13** gets Customers · Archive and Archive · Restore.

3. Add any missing requirements (section 2.3) and save the result as the role's new `permissions`. Everything not in the table stays, because the old system never restricted it.

OLD NO.	WHAT IT MEANT	IF THE ROLE HAD IT, IT GETS THESE NEW PERMISSIONS
3	Edit debtor contact information	**Customers · Edit** `customers.edit` **Customers · Manage flags** `customers.manageFlags`
4	Edit debtor financial details	**Customers · Edit** `customers.edit`
6	Add notes to debtor files	**Customers · Manage flags** `customers.manageFlags` **Notes · Create** `customers.notes.create` **Notes · Edit** `customers.notes.edit` **Notes · Delete** `customers.notes.delete` **Documents · Generate** `customers.documents.generate` **Documents · Delete** `customers.documents.delete`
7	Edit debtor file details	**Customers · Edit** `customers.edit` **Customers · Manage flags** `customers.manageFlags`
11	Stop engagement	**Customers · Stop engagement** `customers.stopEngagement`
12	Resume engagement	**Customers · Resume engagement** `customers.resumeEngagement`
13	Archive debtor files	**Customers · Archive** `customers.archive` **Archive · Restore** `archive.restore`
15	Export debtor files	**Customers · Export** `customers.export`
16	Update assignments	**Customers · Move to team** `customers.moveTeam` **Inbound Inbox · Reassign** `inbox.assign`
18	Update file status	**Customers · Change status** `customers.changeStatus` **Customers · Manage flags** `customers.manageFlags`
23	Make manual outbound calls	**Calls · Place calls** `customers.calls.place`
24	Send SMS and email messages	**SMS & email · Send SMS** `customers.messages.sendSms` **SMS & email · Send email** `customers.messages.sendEmail`

REVIEW ROLES STRAIGHT AFTER CONVERTING

The old system didn't restrict Users, Roles or Settings, so every converted role starts with the sensitive permissions to add and edit users and to create, edit and delete roles. Tenant admins should remove these from every role that shouldn't manage access.

5.10 Security fix: the sender email password FIX

`getTenantDetails` sends the email account's password in plain text to anyone who can open Tenant Settings. Mask it or leave it out, and accept a new password only through `updateTenantDetails` from people with **Tenant settings · Edit**.

SECTION 6 · FOR EVERYONE

6 Rollout plan

The order matters: the backend changes and the role conversion should go live together.

1. **Build and test the changes in section 5.** Use the QA checklist in section 7 against a test workspace. — Backend
2. **Release and convert existing roles in the same step.** If the new format goes live without the conversion, roles would appear to have no permissions. — Backend
3. **The app switches over by itself.** It notices the new format, stops translating old numbers, and unlocks editing on the Roles & Permissions screen. No frontend release is needed. — Automatic
4. **Review every role.** Remove the sensitive user and role permissions from roles that shouldn't manage access (see section 5.9). — Product · Admins
5. **Run the checklist in section 7** on the live environment. — QA
6. **Clean up.** Delete the temporary translation file, `src/lib/permissions/legacy.ts`. — Frontend

ADDING A PERMISSION LATER

Frontend adds it to the catalog file and hides the matching button with it. Backend adds the code name to its list and checks it on the endpoint. If it opens a new page, frontend also adds a page rule. Never rename or reuse an existing code name.

SECTION 7 · FOR QA

7 How to test it

Run these once the backend changes are live. Use a test workspace with a tenant administrator and at least one test user.

#	TRY THIS	WHAT SHOULD HAPPEN
1	Sign in as the tenant administrator and look through the menu.	Every menu item and every button is visible.
2	Open Roles & Permissions.	No "read-only" notice. The New role button is visible.
3	Create a role from the "Collections agent" preset and save it.	The role appears with 14 of 76 permissions.
4	In the editor, turn off Customers · View.	Notes, SMS & email, Calls, Documents and Inbound Inbox switch off too, and a message says so.
5	Give that role to a test user and sign in as them.	The menu shows only Overview, Case Files and Inbound Inbox.
6	As that user, type `/tenant/users` into the address bar.	"Your role can't open this page", naming Users · View.
7	As that user, open a customer and the Manage menu.	Only the allowed tabs show; no Edit details, Move to team or Archive.
8	Remove Send SMS from the role, then refresh as the user.	The SMS box says the role can read but not send.
9	Using the user's token, call a blocked endpoint directly, for example `deleteCustomerNotes` in Postman.	The server refuses: `meta.status: false`, `code: 403`.
10	Try to delete a role that still has users.	Refused, with a message saying how many users to move first.
11	Edit your own role and untick Roles & permissions · Edit.	A warning appears before you save.
12	Change a role while one of its users is signed in.	Their next request follows the new permissions; the menu updates on their next page load.
13	Open an old role created before the conversion.	It has the same access it had before the release.

SECTION 8 · FOR EVERYONE

8 Glossary

The words used in this document, in plain terms.

Role
A named set of permissions, such as "Team lead". Each user has exactly one role.

Permission
Being allowed to do one specific thing, such as "delete notes".

Module
A group in the left menu, such as Case Files or Access Control.

Page
A screen in the app, or a tab on a customer's profile.

Action
Something you can do on a page: View, Create, Edit, Delete, or a special action such as Send SMS.

Code name
The short name the app and server use for a permission, such as customers.notes.delete. Also called a key.

Preset
A ready-made set of permissions to start a new role from.

Sensitive permission
One that controls who can access what, such as adding users or changing roles.

Tenant Administrator
The built-in owner role. Always has every permission and can't be edited or deleted.

Endpoint
An address on the server that the app calls, such as /tenant/getAllRole.

Conversion (migration)
The one-off step that moves existing roles from old numbers to the new code names.

configId
The old numbered permissions that are being replaced.

Read-only
You can see the information but not change it.

403
The standard code for “you're signed in, but not allowed to do this”.

APPENDIX A · FOR BACKEND DEVELOPERS

A Endpoint lookup

Every endpoint the tenant portal calls, in alphabetical order, with the permission the server should check. Where several permissions are listed, any one of them is enough.

ENDPOINT	NEEDS	MEANING
`/tenant/activateUser`	`users.deactivate`	Users · Activate & deactivate
`/tenant/archiveCustomer`	`customers.archive`	Customers · Archive
`/tenant/assignCustomerTag`	`customers.manageFlags`	Customers · Manage flags
`/tenant/assignMovedFileStatusAndUser`	`movedFiles.takeOn`	Moved Files · Take on
`/tenant/assignTeam`	`imports.assignTeam`	Upload customer data · Assign to team
`/tenant/assignTeamList`	Any signed-in user	Team picker (move to team, uploads)
`/tenant/buyNumber`	`phoneNumbers.buy`	Phone numbers · Buy
`/tenant/callCustomerNumberList`	`customers.calls.place`	Calls · Place calls
`/tenant/changeCustomerTeam`	`customers.moveTeam`	Customers · Move to team
`/tenant/changeInitialStatus`	`statusAutomation.edit`	Status automation · Edit
`/tenant/checkInitialStatusUsed`	`statusAutomation.edit`	Status automation · Edit
`/tenant/completeTenantInviteOnboard`	Public, no sign-in	Finish tenant onboarding
`/tenant/createClient`	`clients.create`	Client list · Create
`/tenant/createCustomerNotes`	`customers.notes.create`	Notes · Create
`/tenant/createCustomFields`	`dataFields.create`	Data fields · Create
`/tenant/createDocumentTemplate`	`templates.create`	Template library · Create
`/tenant/createRole`	`roles.create`	Roles & permissions · Create
`/tenant/createStatus`	`statuses.create`	Statuses · Create
`/tenant/createTeam`	`teams.create`	Teams · Create
`/tenant/createTemplate`	`templates.create`	Template library · Create
`/tenant/createUser`	`users.create`	Users · Add
`/tenant/debtorFileDetails`	`imports.view`	Upload customer data · View
`/tenant/deleteClient`	`clients.delete`	Client list · Delete
`/tenant/deleteCustomerDocument`	`customers.documents.delete`	Documents · Delete
`/tenant/deleteCustomerNotes`	`customers.notes.delete`	Notes · Delete
`/tenant/deleteCustomerTag`	`customers.manageFlags`	Customers · Manage flags
`/tenant/deleteCustomFields`	`dataFields.delete`	Data fields · Delete
`/tenant/deleteRole`	`roles.delete`	Roles & permissions · Delete
`/tenant/deleteStatus`	`statuses.delete`	Statuses · Delete
`/tenant/deleteTeam`	`teams.delete`	Teams · Delete

ENDPOINT	NEEDS	MEANING
`/tenant/deleteTemplate`	`templates.delete`	Template library · Delete
`/tenant/disableNumber`	`phoneNumbers.edit`	Phone numbers · Edit
`/tenant/disableUser`	`users.deactivate`	Users · Activate & deactivate
`/tenant/downloadMassUpdateDebtorList`	`massUpdate.export`	Mass update · Download spreadsheet
`/tenant/downloadSampleTemplate`	`imports.upload`	Upload customer data · Upload
`/tenant/enableNumber`	`phoneNumbers.edit`	Phone numbers · Edit
`/tenant/generateCustomerDocuments`	`customers.documents.generate`	Documents · Generate
`/tenant/getAllClients`	`clients.view` *or* `imports.view`	Full client list (also used by the upload screen)
`/tenant/getAllLeaderList`	`teams.create` *or* `teams.edit`	Leader picker on the team form
`/tenant/getAllRole`	`roles.view`	Roles & permissions · View
`/tenant/getAllStatus`	Any signed-in user	Status list with colours
`/tenant/getArchivedCustomers`	`archive.view`	Archive · View
`/tenant/getAuditLogs`	`audit.view`	Activity & audit · View
`/tenant/getclientList`	Any signed-in user	Client picker
`/tenant/getClientTeamStatusList`	`statusAutomation.view`	Status automation · View
`/tenant/getClientTemplate`	`templates.view` *or* `statusAutomation.view`	Templates for a client (also used by status automation)
`/tenant/getCreditorList`	`teamDeck.view`	Team Deck · View
`/tenant/getCustomerCallDetails`	`customers.calls.view`	Calls · View
`/tenant/getCustomerCalls`	`customers.calls.view`	Calls · View
`/tenant/getCustomerDetails`	`customers.view`	Customers · View
`/tenant/getCustomerDocuments`	`customers.documents.view`	Documents · View
`/tenant/getCustomerDocumentTemplateList`	`customers.documents.generate`	Documents · Generate
`/tenant/getCustomerEmail`	`customers.messages.view`	SMS & email · View
`/tenant/getCustomerList`	`customers.view`	Customers · View
`/tenant/getCustomerNotes`	`customers.notes.view`	Notes · View
`/tenant/getCustomerSms`	`customers.messages.view`	SMS & email · View
`/tenant/getCustomerTimeline`	`customers.view`	Customers · View
`/tenant/getCustomFields`	`dataFields.view`	Data fields · View
`/tenant/getDefaultFields`	`dataFields.view`	Data fields · View
`/tenant/getEventList`	`audit.view`	Activity & audit · View
`/tenant/getInboxCustomers`	`inbox.view`	Inbound Inbox · View
`/tenant/getInviteCodeDetails`	Public, no sign-in	Open a tenant invite
`/tenant/getMassUpdateDebtorList`	`massUpdate.view`	Mass update · View
`/tenant/getMovedCustomers`	`movedFiles.view`	Moved Files · View

ENDPOINT	NEEDS	MEANING
`/tenant/getMovedTeamList`	Any signed-in user	Team picker (Moved Files, Archive)
`/tenant/getNumberList`	`phoneNumbers.view`	Phone numbers · View
`/tenant/getNumbers`	`phoneNumbers.buy`	Phone numbers · Buy
`/tenant/getRoleList`	`users.view`	Role picker on the user form
`/tenant/getStatusAutomationDetails`	`statusAutomation.view`	Status automation · View
`/tenant/getStatusAutomationList`	`statusAutomation.view`	Status automation · View
`/tenant/getStatusList`	Any signed-in user	Status picker
`/tenant/getTagList`	`customers.view`	Customers · View
`/tenant/getTeamDeckAssignUserList`	`teamDeck.assign` *or* `movedFiles.takeOn` *or* `inbox.assign` *or* `statusAutomation.view`	Members of a team, for assigning files
`/tenant/getTeamDeckDebtors`	`teamDeck.view`	Team Deck · View
`/tenant/getTeamDeckTeamList`	`teamDeck.view`	Team Deck · View
`/tenant/getTeamDetails`	`teams.view`	Teams · View
`/tenant/getTeamList`	Any signed-in user	Team picker
`/tenant/getTeamNumbers`	`teams.create` *or* `teams.edit`	Number picker on the team form
`/tenant/getTeamPhoneNumber`	`users.create` *or* `users.edit`	Numbers a user can be given
`/tenant/getTeamsCardView`	`teams.view`	Teams · View
`/tenant/getTeamsOrgView`	`teams.view`	Teams · View
`/tenant/getTemplateClients`	`templates.view`	Template library · View
`/tenant/getTenantDetails`	`settings.view`	Tenant settings · View
`/tenant/getTimezoneList`	Any signed-in user	Time zone picker
`/tenant/getTwilioCountries`	`phoneNumbers.buy`	Phone numbers · Buy
`/tenant/getUnassignedTeamMemember`	`teams.create` *or* `teams.edit`	Member picker on the team form
`/tenant/getUploadedDebtor`	`imports.view`	Upload customer data · View
`/tenant/getUsers`	`users.view`	Users · View
`/tenant/inboxAssignUser`	`inbox.assign`	Inbound Inbox · Reassign
`/tenant/initiateCustomerCall`	`customers.calls.place`	Calls · Place calls
`/user/login`	Public, no sign-in	Sign in
`/user/logout`	Any signed-in user	Sign out
`/tenant/makePayment`	Public, no sign-in	Pay during tenant onboarding
`/tenant/myProfile`	Any signed-in user	The signed-in user's own details
`/tenant/releaseNumber`	`phoneNumbers.release`	Phone numbers · Release
`/tenant/resetPassword`	Public, no sign-in	Set a new password from a link

ENDPOINT	NEEDS	MEANING
`/tenant/resetUserPassword`	`users.resetPassword`	Users · Reset password
`/tenant/sendCustomerEmail`	`customers.messages.sendEmail`	SMS & email · Send email
`/tenant/sendCustomerSms`	`customers.messages.sendSms`	SMS & email · Send SMS
`/tenant/sendResetMyPasswordLink`	Any signed-in user	Reset your own password
`/tenant/startEngagement`	`customers.resumeEngagement`	Customers · Resume engagement
`/tenant/stopEngagement`	`customers.stopEngagement`	Customers · Stop engagement
`/tenant/teamDeckAssignUser`	`teamDeck.assign`	Team Deck · Assign to member
`/tenant/UnArchiveCustomer`	`archive.restore`	Archive · Restore
`/tenant/updateAutomation`	`statusAutomation.edit`	Status automation · Edit
`/tenant/updateClient`	`clients.edit`	Client list · Edit
`/tenant/updateCustomerDetails`	`customers.edit`	Customers · Edit
`/tenant/updateCustomerNotes`	`customers.notes.edit`	Notes · Edit
`/tenant/updateCustomerStatus`	`customers.changeStatus`	Customers · Change status
`/tenant/updateCustomFields`	`dataFields.edit`	Data fields · Edit
`/tenant/updateDocumentTemplate`	`templates.edit`	Template library · Edit
`/tenant/updateMassDebtor`	`massUpdate.apply`	Mass update · Apply updates
`/tenant/updateNewDebtor`	`imports.edit`	Upload customer data · Fix records
`/tenant/updateNumberConfig`	`phoneNumbers.edit`	Phone numbers · Edit
`/tenant/updateProfile`	Any signed-in user	Edit your own profile
`/tenant/updateRole`	`roles.edit`	Roles & permissions · Edit
`/tenant/updateStatus`	`statuses.edit`	Statuses · Edit
`/tenant/updateTeam`	`teams.edit`	Teams · Edit
`/tenant/updateTemplate`	`templates.edit`	Template library · Edit
`/tenant/updateTenantDetails`	`settings.edit`	Tenant settings · Edit
`/tenant/updateUser`	`users.edit`	Users · Edit
`/tenant/uploadDebtor`	`imports.upload`	Upload customer data · Upload
`/tenant/uploadProfilePic`	Any signed-in user	Change your own photo
`/tenant/validateDebtorFile`	`imports.upload`	Upload customer data · Upload
`/tenant/validateMassUpdateDebtor`	`massUpdate.apply`	Mass update · Apply updates
`/tenant/validateResetPassword`	Public, no sign-in	Check a password-reset link